RELATÓRIO TÉCNICO

SEGURANÇA DE REDE, ARQUITETURA DE FIREWALL E OTIMIZAÇÃO NGINX

1. Visão Geral do Projeto e Escopo

Este documento apresenta a especificação técnica e a documentação das implementações de segurança de rede, regras de filtragem de tráfego via firewall e configurações de endurecimento (*hardening*) no servidor Web Nginx, desenvolvidas no âmbito do projeto de infraestrutura de redes. O objetivo principal consiste em assegurar o isolamento das zonas da rede, aplicar o princípio do menor privilégio na comunicação entre serviços e proteger a aplicação contra exposição indevida de dados do servidor.

2. Arquitetura de Zonas de Rede

A infraestrutura foi dividida de forma lógica e física através de interfaces dedicadas no servidor Ubuntu Server:

- **WAN (Interface `enp0s3`):** Rede externa / pública com atribuição via DHCP.
- **DMZ - Zona Desmilitarizada (`10.0.1.0/24`, Interface `enp0s8`):** Endereço IP `10.0.1.1`. Hospeda o servidor Nginx a atuar como Proxy Reverso para a aplicação Flask.
- **LAN - Rede Interna (`10.0.2.0/24`, Interface `enp0s9`):** Endereço IP `10.0.2.1`. Destinada a estações de trabalho e acesso administrativo.
- **DB - Zona de Banco de Dados (`10.0.3.0/24`, Interface `enp0s10`):** Endereço IP `10.0.3.1`. Zona isolada onde reside o banco de dados PostgreSQL.

3. Política de Firewall e Regras (nftables)

3.1. Diretrizes de Segurança

- **Políticas Padrão:** As cadeias de entrada (*input*) e encaminhamento (*forward*) adotam política estrita **DROP**, bloqueando por padrão qualquer tráfego não explicitamente permitido.
- **Inspeção de Estado:** Liberação de pacotes com estado `established, related` para permitir respostas a tráfegos legítimos iniciados internamente.
- **Tradução de Endereços (NAT):** Configurado o mascaramento (*masquerade*) para garantir o acesso da rede LAN à internet através da interface WAN.

3.2. Matriz de Conectividade

Zona de Origem	Zona de Destino	Porta / Protocolo	Ação	Finalidade / Justificativa
WAN	**DMZ (Web)**	80/443 TCP	**PERMITIR**	Tráfego público HTTP/HTTPS destinado ao proxy Nginx.
DMZ (Web)	**DB (PostgreSQL)**	5432 TCP	**PERMITIR**	Conexão estrita da aplicação Flask para consulta de dados.
LAN (Admin)	**Todas as Zonas**	22 TCP	**PERMITIR**	Acesso e gerenciamento administrativo seguro via SSH.
DMZ / WAN	**DB (PostgreSQL)**	Todas as outras	**BLOQUEAR**	Isolamento total do banco de dados contra tentativas de intrusão direta.

4. Otimização e Endurecimento no Nginx

4.1. Ocultação de Versão e Hardening (nginx.conf)

Para mitigar varreduras automatizadas e mitigar ataques baseados na identificação de versão da pilha web:

- Aplicada a diretiva `server_tokens off;` no bloco HTTP global.
- Configurado o limite de requisições por IP via `limit_req_zone` para mitigação básica de força bruta e DoS.
- Habilitados os protocolos seguros TLSv1.2 e TLSv1.3.

4.2. Redirecionamento e Tratamento Visual de Erros (nginx-default.conf)

- Redirecionamento automático do tráfego HTTP (porta 80) para HTTPS (porta 443) via `return 301 https://$host$request_uri;`.
- Mapeamento de páginas de erro personalizadas armazenadas em `web/html/`:
  - `error_page 404 /404.html;` — Exibida em requisições a rotas inexistentes.
  - `error_page 500 502 503 504 /50x.html;` — Exibida em indisponibilidade ou falha interna do backend/servidor.

5. Validação de Testes de Integração

1. **Teste de Páginas de Erro:** Requisições para caminhos inválidos retornam o status HTTP 404 exibindo o template customizado sem expor o cabeçalho `Server: nginx/x.x.x`. A simulação de interrupção no serviço Flask dispara o retorno do template `50x.html`.
2. **Teste de Regras de Firewall:** Comunicação TCP na porta 5432 entre o servidor Nginx (`10.0.1.10`) e o servidor PostgreSQL (`10.0.3.1`) foi validada com sucesso. Tentativas de acesso SSH direto vindas da zona DMZ para a zona DB são descartadas (*timeout*) pela regra padrão DROP.